
第9章 可信计算作业

一、填空题

1. 一个可信平台必须包括三个可信根：可信度量根 RTM，可信存储根 RTS，可信报告根 RTR。
2. 平台证明引入了 AIK 对 PCR 值 和 随机数 N 在 TPM 的控制下的签名，保证了平台配置信息的 完整性 和 新鲜性，从而大大提高了通信的 安全性。
3. TPM 只允许两种操作来修改 PCR 的值：重置操作 和 扩展操作。
4. RTM 是平台启动时首先执行的一段程序，它是由 CRTM 控制的计算引擎。

二、选择题

1. 可信计算的安全属性不包括：（ B ）
A. 可鉴别性。 B. 可视性。
C. 完整性。 D. 机密性。
2. 可信计算中，一次度量就是一个度量事件，不包括如下度量事件：（ A ）
A. 完整性报告 B. 嵌入式数据。
C. 程序代码的特征值。 D. 被度量值的散列值。
3. TCG 认为可信平台不包含的可信根是：（ C ）
A. RTM B. RTS
C. PCR D. RTR
4. 下列说法正确的是：（ ABD ）
A. RTR 由 TPM 芯片中的 PCR 和背书密钥组成。
B. EK 可用于创建 TPM 的拥有者。
C. RTS 不包含 PCR。
D. EK 可用于创建 AIK 及其授权数据。
5. 下列可信根中包含 PCR：（ BC ）
A. RTM。 B. RTS。
C. RTR。 D. SRK。

三、简答题

1. 详细分析 PCR 在 TPM 所起到的作用。

答：

(1) PCR 可以使用非易失存储器或易失存储器实现；

(2) TCG 规定每一个 TPM1.1 中有 16 个 PCR，但这个数量太少，因此为了在有限的存储空间中保存平台自上电启动到应用程序加载所参与组件的所有度量信息，TCG 设计了一种方法，即：将需要度量的组件按照功能层次和度量的顺序进行归类，按照预定的顺序依次将度量结果叠加起来，只保存最后的度量结果。这种迭代计算散列值的方法，又称为“扩展（extend）操作”，即

$PCR[n] = SHA-1\{PCR[n-1] \parallel newMeasurement\}$ 。由于度量顺序和组件都固定，因此，只要初始值一定，那么度量结果就是可预期的。PCR 只用于存储扩展后的度量结果。需要注意的是，由于 PCR 记录了平台状态的转换，因此平台转换操作必须要经过度量并扩展到 PCR 中，并且防止软件篡改 PCR 的值。

2. 简述可信计算中的信任根。

答：

(1) RTM：是平台启动时首先执行的一段程序，它是由 CRTM 控制的计算引擎。在理想状态下，CRTM 存储在 TPM 内部，但根据实现的需要，它可能需要加载到其他固件中，如 BIOS。

(2) RTS：由 TPM 芯片中的 PCR 和存储根密钥组成（SRK）组成。TCG 定义的各种密钥是按照树形结构进行组织和管理的，处于上级的父密钥的公钥对处于下级的子密钥进行加密保护，同时配合密钥访问控制机制，确保密钥体系的安全，存储密钥 SK 用于对其他密钥进行存储保护，它也是 RSA 密钥对。这些密钥是分级的，下级的密钥受到上级的存储密钥加密保护，从而构成一个密钥树。出于密钥树根部的密钥是最高级存储密钥，即存储根密钥 SRK，它是 2048 位的 RSA 密钥对，主要用于对 TPM 使用，但存储在 TPM 之外（如硬盘）的密钥进行保护。同时，他作为父密钥对其子密钥进行加密保护。

(3) RTR：由 TPM 芯片中的 PCR 和背书密钥（EK）组成。EK 仅用于以下两种操作：一是创建 TPM 的拥有者；二是创建 AIK 及其授权数据。EK 是唯一的，不做他用。一个 EK 唯一对应一个 TPM，一个 TPM 唯一对应一个平台，因此一个平台只有唯一一个 EK，它是平台的身份标识。AIK 是 EK 的替代物，也是 2048 位的 RSA 密钥。AIK 仅用于对 TPM 内部表示平台可信状态的数据和信息（PCR 值、时间戳、计算器值等数据）进行签名和验证签名，不用于数据加密。注：AIK 不能签名其他非 TPM 状态的数据，这样做的目的是防止攻击者伪造 PCR 让 AIK 签名。

3. 可信计算的基本功能是什么？

答：

（1）完整性度量、存储和报告

完整性度量是一个过程，是在可信平台启动过程中，组件（固件或软件）加载和执行之前，其度量散列值被扩展到了 TPM 内部的平台配置寄存器（PCR）中，通过计算该组件的散列值，并同期望值比较，就可以维护它们的完整性。

完整性报告则是用于验证平台的当前配置，证明完整性存储的过程，展示保护区域内存储的完整性度量值，依靠可信平台的鉴定能力判断存储值的正确性。

（2）平台证明

证明就是确认信息真实性的过程。通过这个过程，外部实体能够确认被保护区域额、受保护能力和信任根，而本地调用不需要证明。通过证明，完成了远程实体对平台身份的认证。由于引入了 AIK 对 PCR 值和随机数 N 在 TPM 的控制下的签名，保证了平台配置信息的完整性和新鲜性，从而大大提高了通信的安全性。

（3）受保护能力

受保护能力就是唯一被许可具有访问被保护区域的特权命令集，而被保护区域就是能够安全操作敏感数据的地方，如：内存、寄存器等。TPM 通过实现受保护能力和被保护区域，来保护和报告完整性度量值。